

Secure Application Development Procedure – Ver. 1.1



Secure Application Development Procedure

Standard Operating Procedure for Secure Application Development

Version	1.1
Effective Date	12/03/2025
Compiled by	Mayur Patekar
Reviewed by	Sumit Rangari
Approved by	Nikhil Bhujade

Revision and Version Control:

Version	Date	Reason for Revision/Update
V1.0	19/03/2024	First Copy
V1.1	12/03/2025	Below changes are added- 1. Components & version in approach doc 2. Phase -3 Implement & Ensure Secure Development Practices 3. Best practices in SSDLC checklist

Distribution List (Stakeholder Signoff):

Sr. No.	Designation	Name
1.	Head – Information Security	Nikhil Bhujade
2.	Head – IT	
3.	Head -ORM	Gaurav Sharma



Secure Application Development Procedure

Contents

I. Introduction.....	4
II. Purpose of the SOP:.....	4
III. Scope of the SOP:.....	4
IV. List of Abbreviations	4
V. Phase -1 Establish the Context of the Security in Designing of Application	4
VI. Phase -2 Implement & Ensure Secure Development Practices:	5
VII. Phase -3 Guidelines for Audit of Applications	6
VIII. Phase -4 Ensure Secure Application Deployment and Operations	7
IX. Review	11

Classification | INTERNAL



Secure Application Development Procedure

I. Introduction

Secure Application Development Procedure ensures that applications are designed, developed, and maintained with robust security measures. By integrating security throughout the lifecycle, we enhance resilience against threats.

II. Purpose of the SOP:

The objective of the SOP is to ensure applications developed, designed, and deployed by PFL or for PFL are in line with the secure development life cycle process as per guidelines from CERT-IN as well as from RBI.

III. Scope of the SOP:

This policy is applicable to in-house developed applications or PLF owned 3rd party applications.

IV. List of Abbreviations

Abbreviation	Full Form / Term/Description
PFL	Poonawalla Fincorp Limited
InfoSec	Information Security
SOP	Standard Operating Procedure
SDLC	Secure Development Life Cycle
API	Application Programming Interface
RPA	Robotic Process Automation
SAST	Static Application Security Testing
DAST	Dynamic Application Security Testing
OWASP	Open Web Application Security Program
UAT	User Acceptance Testing
AD	Active Directory
SBOM	Software Bill of Materials

V. Phase -1 Establish the Context of the Security in Designing of Application

The developer team gathers the requirements, focuses on the functionality, and features as per the requirements of the business team, and prepares an approach document based on that detailed understanding and considering all security requirements.

The first phase of secure application development will be ensured by this examination. This involves establishing the context for security considerations, encompassing not only secure application design but also secure architectural design.

The approach document need to be shared by team in word or PDF format.

Secure Application Development Procedure

Practice	Task
Sharing the Approach Document. These approach documents will give a first-level review from a development and threat modeling standpoint. Developers are well-versed in the application's functionality, data flows, and interface. They can identify potential security weaknesses within the system. This approach document will also help to understand the integration and will also help in infosec due diligence.	The approach document will cover. • Purpose • Business Requirements • Severity of Application (High, Medium, Low) • Components used and their versions • Solution approach • Architecture • Data flow diagrams / workflow and data fields • API details (internal and external) • Workflow descriptions • Implementation methodologies and adopted framework. Link-  Secure_SDLC_frame work.xlsx Template -  Approach%20Document%20Template.d Along with the checklist mention in the phase-2

VI. Phase -3 Implement & Ensure Secure Development Practices:

The development team must adhere to secure application development practices outlined in a checklist format. These practices include secure coding, input validation, output encoding, session management, Version Control and Change management, authentication, and authorization.

The development team needs to share the Secure Application Development Checklist. This checklist will serve as a quick reference guide for developers, highlighting essential security steps.

A Software Bill of Materials is a comprehensive list of all components, libraries, and modules that constitute the software, ensuring transparency in its composition. The application development team and the designated application SPOC for both in-house and third-party SaaS applications must maintain and periodically review the SBOM to verify that it includes all third party libraries in use.

Secure Application Development Procedure

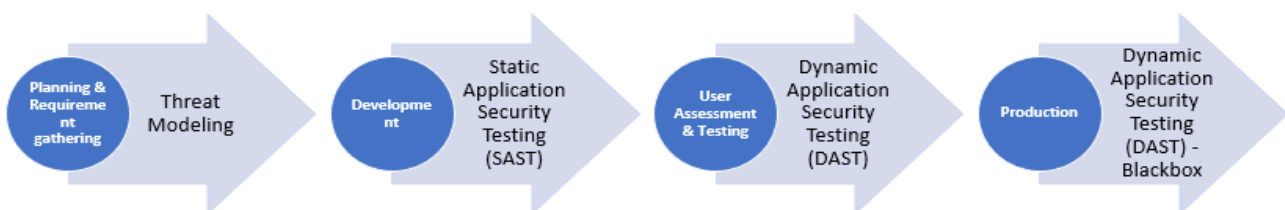
Practice	Task
Define and Use Criteria for Software Security Checks (in the form of a checklist)	Secure Application Development Checklist (which cover all the points highlighted in the CERT-IN Guidelines) This checklist will serve as a quick reference guide for developers, highlighting essential security steps.  Worksheet%20in%20https%20%20%20p Link -

Infosec will Record security checks, approvals, rejections, and exception requests as part of the workflow and tracking system.

VII. Phase -4 Guidelines for Audit of Applications

During the different development phases of web application/API/RPA/Bot, etc., it is recommended to assess applications with security assessment. Below fig. 1 represents Application Security assessment with respect to development stages.

It is recommended that Secure SDLC must be followed from the initial stage to ensure the security of application maintain throughout development phases.



Ref: https://owasp.org/www-project-web-security-testing-guide/stable/3-The_OWASP_Testing_Framework/0-The_Web_Security_Testing_Framework

To undertake a security audit of the application and its relevant components at different level infosec will get this testing carried out through a CERT-In, an accredited auditing organization. The audit's goal according to thorough standards and frameworks like the Cyber Security Audit Baseline Requirements, OWASP Application Security Verification,

Secure Application Development Procedure

OWASP Web Security Testing Guide, Mobile Application Security Verification Standard, Mobile Application Security Testing Guide , and OWASP Application Programming Interface.

The development team should fix any critical vulnerabilities found in audit reports right away and confirm them with Infosec for revalidation. Periodically, the infosec team will undertake vulnerability assessments, ideally once a year or whenever there is an application change. Below summary of the Turnaround Time (TAT) for various application security assessment activities:

Activity	Description	Best Phase	Infosec Estimated Assessment TAT
Threat Modeling	Proactively identifies security risk by reviewing approach Document (Analyzes architecture, design, data flow, data field and infrastructure.)	Early stages of SDLC	4-5 Days
Source Code review, API Testing	White-box method examining code for flaws (e.g., SQL injection).	Throughout SDLC	2-3 Days
DAST / Grey Box Assessment (Dynamic Application Security Testing)	Black-box / grey box method assessing running applications for vulnerabilities.	Environment similar to production	5 Days

Recommendations Note :



Secure_Application_Development_Procedure.pdf

Infosec will perform the Mobile App(Android & iOS) testing as per the checklist



Android_Penetration_Testing_Checklists.pdf



iOS_Penetration_Testing_Checklists.pdf

VIII. Phase -5 Ensure Secure Application Deployment and Operations

- Once the infosec team has carried out the assessment and approved, the IT development team needs to make sure that they will not make changes to the audited code or configuration or any change in the develop application.
- Developer and IT has to ensure that all features are meticulously designed with backward compatibility in mind, and steer clear of making incompatible changes to existing APIs and data structures. In case vulnerabilities are discovered in the



Secure Application Development Procedure

application, there should be a structured process to apply patches or fixes. This involves testing patches to ensure they don't introduce new issues / vulnerabilities,

maintaining a change control process for documentation and accountability, and communicating changes to relevant stakeholders

- While using container engine (Docker), container orchestration (Kubernetes) tool make sure their best security practices are adhered
- It is the responsibility of the IT development team to implement and maintain secure CI/CD pipelines with robust enforcement of security checks.
- Use up-to-date versions of compiler, interpreter, and build tools.
- The development team has to implement RBAC for developer controls on code-sharing platforms

Below is the RACI Matrix for phase 1, Phase 2, Phase 3, and Phase 4

Phases	Task	Responsible	Accountable	Consulted	Informed
Phase 1	Sharing the Approach Document.	IT Development Team will share the Approach Document with Infosec and Business Team	IT Development Team	Infosec Business Team	Key stakeholder IT Development Team, InfoSec, Business Team
	Arrange Walkthrough for InfoSec Understanding	IT Development Team	IT Development Team	Infosec	Key Stakeholder IT development Team, Business Team
	Threat Modeling Assessment (overview of data flow, define trust boundaries, and/or trust models)	Infosec Team	IT Development Team	InfoSec, Business Team	IT Development Team, InfoSec, Business Team
	Risk remediation and countermeasure	IT Development Team	IT Development Team	InfoSec	IT Development Team, InfoSec, Business Team



Secure Application Development Procedure

Phases	Task	Responsible	Accountable	Consulted	Informed
Phase 2	Secure Development Checklist	IT Development Team	IT Development Team Head	InfoSec	Key stakeholder IT Development Team, InfoSec, Business Team
Phase 3	Threat Modeling Assessment (overview of data flow, define trust boundaries, and/or trust models)	Infosec Team IT Development Team	IT Development Team	InfoSec, Business Team	IT Development Team, InfoSec, Business Team
	Source Code Review Static Application Security Testing (SAST)	InfoSec Team IT Development Team	Project IT SPOC IT Development Team	IT Development Team	InfoSec Team, Business Team, IT development Team
	DAST / Grey Box Assessment (Dynamic Application Security Testing)	InfoSec Team IT Development Team	Project IT SPOC IT Development Team	IT Development Team	InfoSec Team, Business Team, IT development Team
Phase 4	CI /CD pipeline configuration Git hub Integration	IT development Team (Devops) (Need to fix the vulnerabilities and Alert)	Infosec (to check alerts and vulnerabilities in the CSPM Dashboard)	IT development Team	InfoSec Team, Business Team, IT development Team
	Remediate Security Findings	IT development Team (DevOps)	IT development Team (DevOps)	Infosec	InfoSec Team, IT development Team,
Miscellaneous	Change management.	IT development Team	IT Development Team	Infosec Business SPOC	Key Business Stakeholder



Secure Application Development Procedure

Phases	Task	Responsible	Accountable	Consulted	Informed
	Audit trail logs	IT development Team	IT development Team	Infosec Business SPOC	Key Business Stakeholder
	DR arrangement as per IT and Business	IT development Team	IT Infra Team	Infosec Business SPOC	Key Business Stakeholder
	Application config and Backup	IT development Team	IT Infra Team IT Development Team	Infosec Business SPOC	Key Business Stakeholder
	Production and UAT environment segregation	IT development Team	IT Infra Team IT Development Team	Infosec Business SPOC	Key Business Stakeholder
Server Hardening (where application is deployed in production)	• AV/ED • Latest Patches, • domain Joining(Windows) • WAF (If exposed to internet) • Restrict Internet access to server • Allowing approved port on security group/ firewall • Server/ application Database	IT Infra Team IT Development Team	IT Infra Team IT Development Team	Infosec	infosec Key Business Stakeholder



Secure Application Development Procedure

Phases	Task	Responsible	Accountable	Consulted	Informed
	Behind PAM				

The developer team can refer to the Secure SDLC framework and choose the one that is best suited for the development. These SDLC Framework are:

Microsoft Secure Development Lifecycle (SDL):

Link : [Microsoft Security Development Lifecycle Practices](#)

Open Web Application Security Project (OWASP) Software Assurance Maturity Model (SAMM)

Link : [OWASP SAMM | OWASP Foundation](#)

OWASP ASVS cheat sheet

[Index ASVS - OWASP Cheat Sheet Series](#)

Agile Secure Development Lifecycle

Link : <https://snyk.io/learn/secure-sdlc/agile-sdlc/>

NIST Secure Software Development Framework (SSDF)

Link : [Secure Software Development Framework | CSRC \(nist.gov\)](#)

IX. Review

This SOP shall be reviewed at least annually or as and when required and all relevant stakeholders' sign off shall be obtained.

All the relevant documents like checklist, approach document, assessment reports and trackers will be maintained by Infosec.